

Project Report: Security Group Analyzer

Cloud VM Firewall Misconfiguration Simulator

Case Study 88: Security Group Misconfiguration Attack Simulation

Student Name: Jason

Course: B.Tech Computer Science & Engineering

1. Executive Summary

This project demonstrates the design and deployment of a full-stack Cloud Security Posture Management (CSPM) application. The system acts as a Centralized Security Operations Center (SOC) to automatically audit, analyze, and remediate cloud network vulnerabilities. By integrating a React frontend, a Python FastAPI backend, a MongoDB Atlas database, and the AWS Boto3 API, the tool programmatically identifies severe firewall misconfigurations and enforces the Principle of Least Privilege across cloud deployments.

2. Problem Statement

Industry: Cybersecurity

A cloud Virtual Machine (AWS EC2) was configured with open access on all inbound ports (0.0.0.0/0). This severe misconfiguration exposes the infrastructure to the public internet, leading to critical security vulnerabilities such as SSH brute-force attacks, unauthorized database access, and ransomware deployment.

3. Technical Implementation

To resolve the vulnerability without disrupting necessary web services, the following technical implementations were executed:

- **Identifying Risky Inbound Rules:** The Python backend utilizes the AWS Boto3 SDK to securely authenticate with the cloud environment via Read-Only IAM access keys. It dynamically fetches the live Security Group rules and flags any port allowing unrestricted 0.0.0.0/0 access.
- **Modifying Rules for Necessary Traffic:** The system calculates a secure configuration state. It intentionally leaves Port 80 (HTTP) open to 0.0.0.0/0 to allow legitimate web traffic, but restricts critical administrative ports.
- **Applying the Principle of Least Privilege:** Port 22 (SSH) is strictly locked down to a single authorized IP address (e.g., 203.0.113.0/24). This ensures that only authorized administrators on a trusted network can attempt remote server access, eliminating the global attack surface.

4. Product Building: The Security Dashboard

The solution was packaged into a full-stack web application to provide a scalable product for Security Operations teams.

- **Automated Risk Assessment:** The dashboard visualizes the live AWS configuration, instantly scoring the network's security posture out of 100 based on exposed ports and associated threat vectors.
- **Secure Configuration Checklist:** A dynamic checklist evaluates the VM deployment against industry compliance standards, ensuring no unrestricted access exists on ALL ports, RDP (3389) is hidden, and databases are protected.
- **Demonstrating a Hardened Perimeter:** The user interface provides a clear "Before and After" analysis, proving the exact remediation steps required to secure the perimeter.
- **Immutable Audit Logging:** Every time a security fix is generated, the backend asynchronously writes an audit trail to a MongoDB Atlas cloud database. This satisfies compliance requirements by logging the timestamp, the acting user, and the shift in the security score.

5. Security Testing & Validation

To physically prove the vulnerability and the subsequent fix, active network penetration testing was conducted alongside the API-level auditing.

- **Vulnerability Verification:** Manual Nmap network scans (`nmap -Pn <EC2_IP>`) were executed against the target instance, confirming that Port 22 and Port 80 were physically exposed to external attackers.
- **Post-Remediation Validation:** After applying the Principle of Least Privilege to the AWS Security Group, follow-up Nmap scans confirmed that Port 22 was successfully `filtered` (dropping unauthorized packets), while Port 80 remained `open` for normal business operations.

6. Business Impact & Revenue Model

Because the application leverages native AWS Security Groups and open-source infrastructure, the operational cost (COGS) is near zero. This allows for a highly profitable B2B SaaS (Software as a Service) revenue model while simultaneously saving the client money.

- **Revenue Generation (SaaS Pricing Tiers):** The product is monetized through a tiered subscription model targeting IT and Security teams:
 - **Basic Tier (Freemium - Lead Generation):** ₹0/month. Allows organizations to run read-only automated risk assessments on a single AWS instance. This acts as a hook to prove the product's value.
 - **Professional Tier (Core Revenue):** ₹4,999/month per AWS Account. Unlocks the "1-Click Remediation" feature, continuous automated API auditing, and immutable MongoDB audit logging for compliance tracking.
 - **Enterprise Tier:** Custom pricing (e.g., ₹50,000+/month). Unlocks multi-cloud support, custom compliance checklists (such as DPDP Act standards), and dedicated SOC team integrations.

- **The "Zero-Cost" Infrastructure Advantage:** We achieve incredibly high profit margins because we do not sell expensive hardware firewalls. Instead, our software programmatically configures the client's *existing*, free AWS Security Groups.
- **Value-Based Selling (Cost of Inaction):** Clients willingly pay the subscription fee because the tool specifically mitigates catastrophic financial risks. By instantly identifying `0.0.0.0/0` misconfigurations, it protects the company from data breaches, regulatory fines, and unauthorized EC2 resource hijacking (crypto-mining), which can cost millions of rupees.

7. Conclusion

This project successfully satisfies all requirements of Case Study 88. By combining offensive network testing (Nmap) with automated defensive API auditing (AWS Boto3), the resulting application provides a robust, highly scalable, and commercially viable solution to cloud firewall misconfigurations.
